



MITIGAÇÕES IMPLEMENTADAS E AMBIENTE REFORÇADO

Equipe: AptX Team

Integrantes: Eduardo Gutierrez, Felipe Ribeiro de Carvalho, Leonardo Oliveira Feitosa, Matheus Patrick, Renan Ribeiro Almeida.



Sumário:

1. Objetivo.....	2
2. Lista de Vulnerabilidades Identificadas.....	3
3. Mitigações Aplicadas.....	4
4. Hardening Implementado.....	5
5. Comparativo do Ambiente Antes e Depois das Mitigações.....	6
6. Novos Controles Implementados.....	7
7. Nova Política de Logging.....	8
8. Teste de Reataque (Validação Técnica).....	9
9. Plano de Melhoria Contínua.....	10
10. Conclusão.....	11
11. Evidências Técnicas:.....	12



1. Objetivo

Após a execução da simulação de ransomware com vetor inicial de phishing, foi realizada uma revisão completa da infraestrutura do Hospital Vida Plena. O objetivo desta etapa foi eliminar vulnerabilidades identificadas, fortalecer os controles de segurança, ampliar a capacidade de monitoramento e validar a eficácia das melhorias por meio de um novo teste controlado.

2. Lista de Vulnerabilidades Identificadas

Durante a análise realizada após a simulação do incidente de ransomware, foram identificadas diversas fragilidades na infraestrutura do Hospital Vida Plena. Entre os principais problemas encontrados estavam a utilização do protocolo SMBv1 em um servidor Windows Server 2008 sem suporte do fabricante, a ausência de segmentação de rede e permissões excessivas em compartilhamentos de arquivos. Também foram observadas deficiências relacionadas ao monitoramento, como a descentralização dos logs, a inexistência de uma solução SIEM para correlação de eventos e a falta de mecanismos de monitoramento de integridade de arquivos.

Além disso, o ambiente não possuía alertas automáticos para eventos críticos, nem controles específicos para detecção e bloqueio de comportamentos associados a ransomware. Foi constatada ainda a ausência de programas de conscientização contra phishing e a existência de contas privilegiadas sem controles adicionais de segurança, as principais vulnerabilidades abaixo estavam em evidência:

- **SMBv1 habilitado no Windows Server 2008.**
- **Sistema operacional legado sem suporte (Windows Server 2008).**
- **Ausência de segmentação de rede.**
- **Permissões excessivas em compartilhamentos SMB.**
- **Logs descentralizados sem correlação.**
- **Ausência de SIEM.**
- **Ausência de monitoramento de integridade de arquivos.**
- **Ausência de alertas automáticos.**
- **Falta de proteção contra ransomware.**
- **Ausência de conscientização contra phishing.**
- **Contas privilegiadas sem controles adicionais.**

3. Mitigações Aplicadas

Com base nas vulnerabilidades identificadas, foi executado um plano de remediação abrangente para fortalecer a infraestrutura. A principal ação consistiu na migração do Windows Server 2008 para Windows Server 2022, eliminando os riscos associados ao uso de um sistema operacional obsoleto. Paralelamente, foram aplicadas atualizações de segurança em todos os ativos afetados e o protocolo SMBv1 foi removido definitivamente do ambiente.

As permissões de acesso aos compartilhamentos foram revisadas de acordo com as necessidades operacionais de cada setor, reduzindo a superfície de exposição. Para aprimorar a capacidade de monitoramento e detecção, foram implantadas as plataformas Wazuh e Security Onion, possibilitando a centralização dos logs e a correlação de eventos de segurança.

Também foram configurados alertas automáticos por e-mail para eventos críticos e habilitado o recurso de File Integrity Monitoring (FIM), permitindo identificar alterações não autorizadas em arquivos sensíveis. Como medida complementar, todas as credenciais potencialmente comprometidas foram redefinidas e as contas privilegiadas do Active Directory passaram por revisão e adequação.

4. Hardening Implementado

Após a aplicação das medidas corretivas, foi conduzido um processo de hardening nos sistemas e serviços críticos. O princípio do menor privilégio foi adotado em toda a infraestrutura, restringindo acessos administrativos apenas aos usuários que realmente necessitam dessas permissões.

Nos servidores Debian, foram aplicadas configurações de endurecimento do serviço SSH, reduzindo a exposição a tentativas de acesso indevido. Também foram implementados mecanismos para bloqueio da execução de arquivos suspeitos, bem como regras restritivas de firewall por meio do OPNsense.

A segmentação da rede foi reforçada para limitar a movimentação lateral de ameaças, enquanto serviços desnecessários foram desabilitados para reduzir a superfície de ataque. O monitoramento de eventos dos sistemas Windows e Linux também foi expandido, aumentando a visibilidade sobre atividades potencialmente maliciosas.

5. Comparativo do Ambiente Antes e Depois das Mitigações

Aspecto Avaliado	Antes das Mitigações	Depois das Mitigações
Sistema Operacional	Windows Server 2008 (sem suporte do fabricante).	Windows Server 2022 com suporte e atualizações de segurança.
Protocolo SMB	SMBv1 habilitado, sujeito a vulnerabilidades conhecidas.	SMBv1 completamente removido.
Monitoramento de Segurança	Inexistência de solução SIEM.	Implantação do Wazuh e Security Onion para monitoramento centralizado.
Gestão de Logs	Logs distribuídos e sem correlação entre eventos.	Logs centralizados com correlação automática de eventos.
Alertas de Segurança	Ausência de notificações automáticas.	Alertas automáticos enviados por e-mail para eventos críticos.
Integridade de Arquivos	Não havia monitoramento de alterações em arquivos críticos.	File Integrity Monitoring (FIM) habilitado e monitorado continuamente.
Proteção contra Ransomware	Nenhum mecanismo específico de detecção ou bloqueio.	Regras personalizadas para detecção e bloqueio de comportamentos associados a ransomware.

A comparação demonstra uma evolução significativa na postura de segurança do Hospital Vida Plena. O ambiente anteriormente apresentava limitações relacionadas à visibilidade, monitoramento e resposta a incidentes. Após a implementação das medidas corretivas e dos novos controles de segurança, a infraestrutura passou a contar com mecanismos avançados de detecção, correlação de eventos e proteção contra ameaças, aumentando substancialmente sua capacidade de prevenção, identificação e resposta a incidentes cibernéticos.

6. Novos Controles Implementados

Wazuh:

- Correlação de eventos.
- HIDS.
- FIM.
- Regras personalizadas de ransomware.

Security Onion:

- Monitoramento de rede.
- IDS.
- Correlação de eventos.

Alertas por e-mail:

- Notificação imediata de eventos críticos pelo NDR e pelo EDR.

Snapshots Proxmox:

- Recuperação rápida do ambiente.

Controle de Phishing:

- Bloqueio de extensões duplas.
- Procedimentos de validação de anexos.

7. Nova Política de Logging

Como parte do processo de fortalecimento da infraestrutura de segurança do Hospital Vida Plena, foi implementada uma nova política de gerenciamento e centralização de logs. Anteriormente, os registros de eventos encontravam-se distribuídos entre diferentes sistemas, dificultando a correlação de informações e aumentando o tempo necessário para identificar atividades suspeitas.

Com a implantação do Wazuh, todos os logs relevantes passaram a ser coletados, normalizados e centralizados em uma única plataforma, proporcionando maior visibilidade sobre os eventos ocorridos no ambiente. Essa centralização permitiu a criação de regras de correlação e alertas automáticos, melhorando significativamente a capacidade de detecção e resposta a incidentes de segurança.

A nova política contempla o monitoramento contínuo de diversas fontes de eventos, incluindo registros do Windows Event Viewer, eventos avançados coletados pelo Sysmon, logs de autenticação dos sistemas Linux (Auth.log), registros do Syslog, logs de firewall e rede provenientes do OPNsense, eventos do Active Directory e alertas gerados pelo Security Onion. Dessa forma, tornou-se possível obter uma visão consolidada das atividades realizadas em toda a infraestrutura.

Além da coleta centralizada, foram definidos critérios específicos para identificação de eventos críticos. Entre eles destacam-se os eventos de autenticação bem-sucedida (Event ID 4624), falhas de autenticação (Event ID 4625), criação de novos processos (Event ID 4688), alterações em arquivos sensíveis monitorados pelo File Integrity Monitoring (FIM), tentativas de acesso via SSH e execuções classificadas como suspeitas pelas regras de detecção implementadas.

Os resultados obtidos demonstraram uma evolução significativa na capacidade operacional do ambiente. Antes da implementação da nova política de logging, o tempo médio para identificação de atividades maliciosas era superior a 15 minutos devido à necessidade de análise manual de múltiplas fontes de informação. Após a centralização dos registros e a configuração de alertas automatizados, o tempo estimado de detecção foi reduzido para menos de 1 minuto, permitindo uma resposta muito mais rápida a possíveis incidentes de segurança.

8. Teste de Reataque (Validação Técnica)

Após a implementação das melhorias, foi realizado um novo teste controlado utilizando o mesmo cenário de phishing empregado na fase inicial da simulação. O objetivo foi verificar a eficácia dos controles implantados e medir a capacidade de detecção e resposta do ambiente.

Durante a execução do teste, o artefato malicioso foi identificado pelo Wazuh logo após sua execução. As regras personalizadas desenvolvidas para detecção de ransomware classificaram a atividade como crítica e acionaram automaticamente os mecanismos de resposta configurados. O processo associado à ameaça foi bloqueado antes que pudesse desenvolver a criptografia de todos os arquivos monitorados.

Simultaneamente, alertas foram enviados por e-mail para a equipe responsável, enquanto os eventos foram correlacionados pelo EDR, permitindo uma visão consolidada do incidente. Ao final da validação, constatou-se que nenhum arquivo das áreas protegidas sofreu criptografia ou alteração indevida, demonstrando um aumento significativo da resiliência do ambiente diante do mesmo vetor de ataque utilizado anteriormente.

9. Plano de Melhoria Contínua

Embora as medidas implementadas tenham elevado significativamente o nível de segurança do ambiente, a proteção cibernética deve ser tratada como um processo contínuo de evolução e aperfeiçoamento. Dessa forma, foi definido um plano de melhoria contínua estruturado em diferentes níveis de prioridade, visando manter a resiliência do Hospital Vida Plena frente às ameaças atuais e futuras.

Como ações de alta prioridade, recomenda-se a realização periódica de treinamentos de conscientização sobre phishing e engenharia social para todos os colaboradores, reduzindo a probabilidade de comprometimento por meio do fator humano. Também deverão ser executadas simulações regulares de incidentes de segurança, permitindo validar processos de resposta e aprimorar a preparação das equipes envolvidas. Adicionalmente, será adotada uma revisão trimestral das permissões de acesso, garantindo que os privilégios concedidos permaneçam alinhados às funções e responsabilidades de cada usuário.

Em médio prazo, prevê-se a ampliação da segmentação de rede para áreas adicionais da infraestrutura, reduzindo ainda mais a possibilidade de movimentação lateral por agentes maliciosos. Paralelamente, será implementada a autenticação multifator (MFA) para todos os usuários e sistemas críticos, fortalecendo os mecanismos de controle de acesso e mitigando riscos relacionados ao comprometimento de credenciais.

Como objetivo estratégico de longo prazo, o hospital buscará evoluir sua arquitetura de segurança para um modelo baseado nos princípios de Zero Trust, no qual nenhum usuário ou dispositivo é considerado confiável por padrão. Além disso, serão estabelecidos processos permanentes de gestão de vulnerabilidades, incluindo identificação, avaliação e correção contínua de falhas de segurança. Auditorias periódicas também serão realizadas para validar a conformidade dos controles implementados e identificar oportunidades adicionais de melhoria.

A adoção dessas iniciativas garantirá que os avanços obtidos durante o processo de resposta ao incidente sejam preservados e continuamente aprimorados, fortalecendo a postura de segurança da organização ao longo do tempo.

10. Conclusão

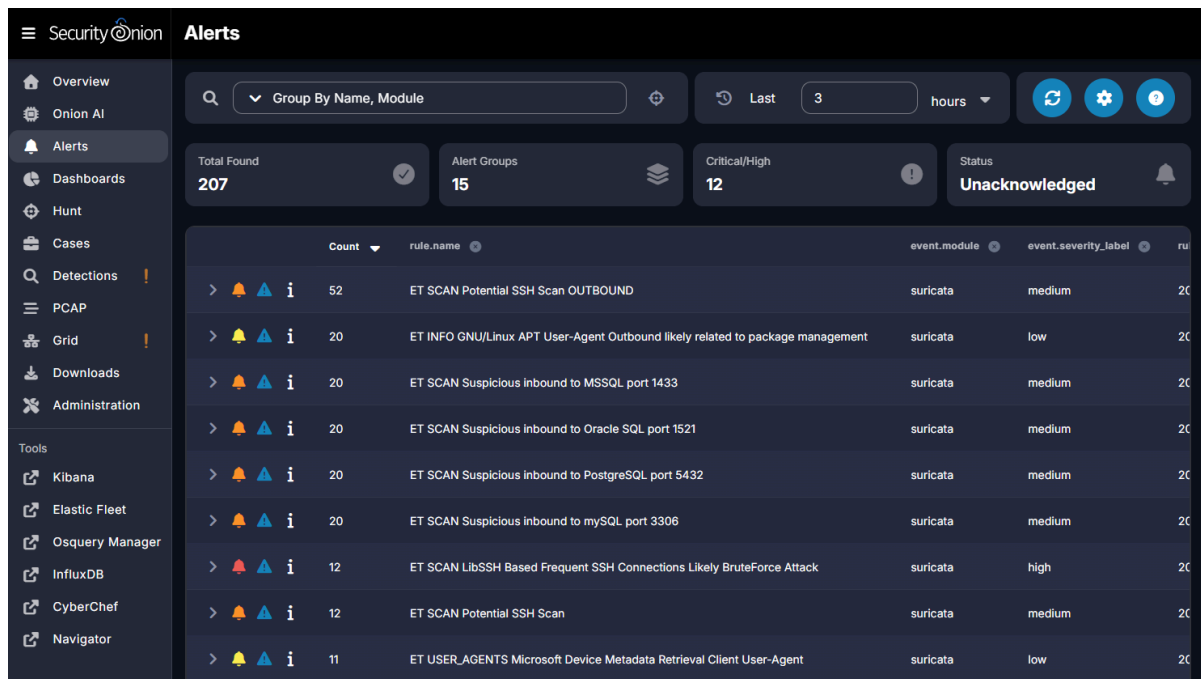
A simulação do ataque de ransomware permitiu identificar vulnerabilidades relevantes na infraestrutura do Hospital Vida Plena e demonstrou a necessidade de adoção de controles mais robustos de segurança da informação. A partir dos resultados obtidos, foi conduzido um processo abrangente de remediação, contemplando a modernização dos sistemas, a implementação de mecanismos avançados de monitoramento e a aplicação de práticas de hardening voltadas à redução da superfície de ataque.

Entre as principais melhorias realizadas destacam-se a migração do ambiente para Windows Server 2022, a implantação do Wazuh como plataforma central de monitoramento e correlação de eventos, a integração com o Security Onion para visibilidade de rede, a centralização dos logs de segurança, a configuração de alertas automáticos, a implementação do File Integrity Monitoring (FIM), a segmentação da rede e a criação de regras específicas para identificação e bloqueio de comportamentos associados a ransomware.

Os resultados foram validados por meio da execução de um novo teste utilizando o mesmo vetor de ataque empregado na fase inicial do projeto. Durante a simulação, os mecanismos de monitoramento identificaram rapidamente a atividade maliciosa, os alertas foram acionados em tempo real e as ações de contenção impediram a criptografia dos arquivos monitorados. O tempo estimado de detecção foi reduzido de mais de quinze minutos para menos de um minuto, demonstrando uma melhoria substancial na capacidade de resposta da organização.

Dessa forma, conclui-se que as medidas implementadas elevaram significativamente o nível de maturidade em segurança cibernética do Hospital Vida Plena, proporcionando maior visibilidade sobre os eventos do ambiente, redução dos riscos operacionais e aumento da capacidade de prevenção, detecção e resposta a incidentes. Embora a segurança seja um processo contínuo, os resultados obtidos demonstram que a organização se encontra significativamente mais preparada para enfrentar ameaças semelhantes no futuro.

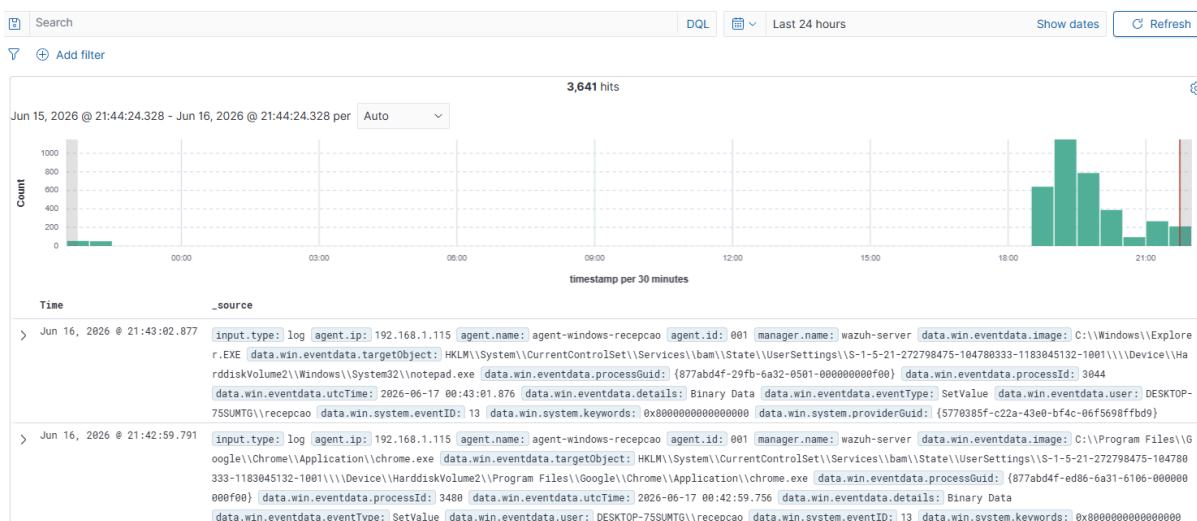
11. Evidências Técnicas:



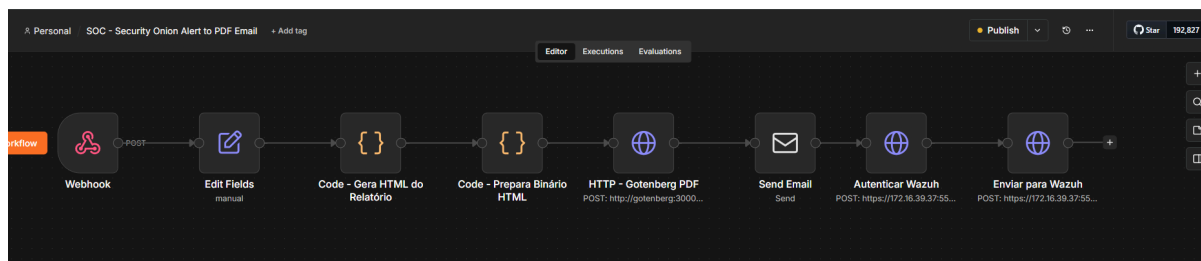
The screenshot shows the Security Onion Alerts dashboard. On the left is a sidebar with navigation options: Overview, Onion AI, Alerts (selected), Dashboards, Hunt, Cases, Detections, PCAP, Grid, Downloads, and Administration. Below these are Tools: Kibana, Elastic Fleet, Osquery Manager, InfluxDB, CyberChef, and Navigator. The main area is titled 'Alerts' and features a search bar with 'Group By Name, Module'. It displays summary statistics: Total Found (207), Alert Groups (15), Critical/High (12), and Status (Unacknowledged). A table lists alerts with columns for Count, rule.name, event.module, event.severity_label, and ru. The table shows several alerts related to ET SCAN and ET USER_AGENTS.

Count	rule.name	event.module	event.severity_label	ru
52	ET SCAN Potential SSH Scan OUTBOUND	suricata	medium	20
20	ET INFO GNU/Linux APT User-Agent Outbound likely related to package management	suricata	low	20
20	ET SCAN Suspicious inbound to MSSQL port 1433	suricata	medium	20
20	ET SCAN Suspicious inbound to Oracle SQL port 1521	suricata	medium	20
20	ET SCAN Suspicious inbound to PostgreSQL port 5432	suricata	medium	20
20	ET SCAN Suspicious inbound to MySQL port 3306	suricata	medium	20
12	ET SCAN LibSSH Based Frequent SSH Connections Likely BruteForce Attack	suricata	high	20
12	ET SCAN Potential SSH Scan	suricata	medium	20
11	ET USER_AGENTS Microsoft Device Metadata Retrieval Client User-Agent	suricata	low	20

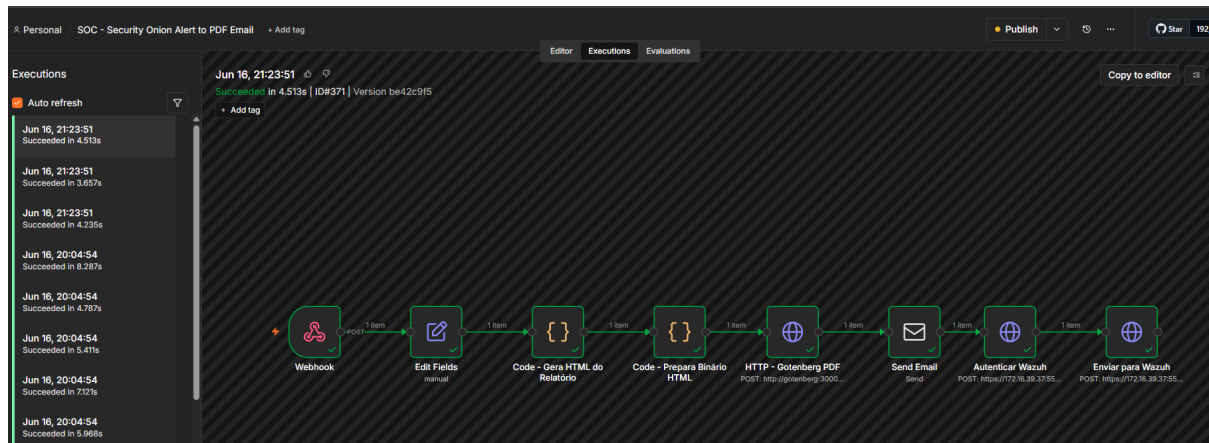
Anexo 1: Alertas no Security Onion.



Anexo 2: Logs do Windows no Wazuh.



Anexo 3: Workflow para automação de notificação.



Anexo 4: Execução do workflow.

Rules (2)

From here you can manage your rules.

Manage rules files Add new rules file Refresh Export formatted

109500 WQL Custom rules

ID	Description	Groups	Level	File	Path
109500	Ransomware: extensao suspeita criada por win.eventdata.image	ransomware, sysmon	12	ransomware_rules.xml	etc/rules
109500	Ransomware: extensao suspeita criada por win.eventdata.image	ransomware, sysmon	12	ransomware_rules.xml	etc/rules

Rows per page: 10

Anexo 5: Rules personalizadas no Wazuh.

ransomware_rules.xml

```

1 <group name="ransomware, sysmon, ">
2
3 <!-- Extensoes conhecidas de ransomware no FileCreate (Event 11) -->
4 <rule id="109500" level="12">
5   <if_group>sysmon_event_11</if_group>
6   <field name="win.eventdata.targetFilename" type="pcr2">(?!)\.(locked|encrypted|crypto|crypt|enc|ransom|crypted|cryptolocker|locky|cerber|zepto|thor|WCRY|WNCRY|ryuk|conti|revil|darkside|blackcat|lockbit)$
7   </field>
8   <description>Ransomware: extensao suspeita criada por $(win.eventdata.image)</description>
9   <mitre><id>T1486</id></mitre>
10 </rule>
11
12 <!-- FileCreate massivo do mesmo processo -->
13 <rule id="109501" level="13" frequency="50" timeframe="30">
14   <if_matched_sid>109500</if_matched_sid>
15   <same_field>win.eventdata.image</same_field>
16   <description>Ransomware: criacao massiva de arquivos criptografados por $(win.eventdata.image)</description>
17   <mitre><id>T1486</id></mitre>
18 </rule>
19
20 <!-- Ransom note criada -->
21 <rule id="109502" level="14">
22   <if_group>sysmon_event_11</if_group>
23   <field name="win.eventdata.targetFilename" type="pcr2">(?!)(READ|WRITE|DECRYPT|RECOVER|RESTORE|HOW.YOUR.FILES|HELP|DECRYPT)\.(txt|html|hta|url)$</field>
24   <description>Ransomware: nota de resgate criada em $(win.eventdata.targetFilename)</description>
25   <mitre><id>T1486</id></mitre>
26 </rule>
27
28 <!-- Shadow copy deletado -->
29 <rule id="109503" level="14">
30   <if_group>sysmon_event_1</if_group>
31   <field name="win.eventdata.commandLine" type="pcr2">(?!)(vssadmin|wmic|wbadmin)\.(delete|resize|shadowcopy)</field>
32   <description>Ransomware: delecao de shadow copies por $(win.eventdata.image)</description>
33   <mitre><id>T1498</id></mitre>
34 </rule>
35

```

Anexo 6: Trecho do script personalizado para parar o ransomware.

Rules (4,440) Manage rules files Add new rules file Refresh Export formatted

From here you can manage your rules.

relative_dirname=etc/rules WQL Custom rules

ID ↑	Description	Groups	Regulatory compliance	Level	File	Path
100001	sshd: authentication failed from IP 1.1.1.1.	authentication_failed, local, syslog, sshd	POL_DSS	5	local_rules.xml	etc/rules
100001	sshd: authentication failed from IP 1.1.1.1.	authentication_failed, local, syslog, sshd	POL_DSS	5	local_rules.xml	etc/rules
100002	Security Onion - Alerta de Alta Severidade	security_onion		12	security_onion_rules.xml	etc/rules
100002	Security Onion - Alerta de Alta Severidade	security_onion		12	security_onion_rules.xml	etc/rules
100002	Suricata Traffic - event_type .	suricata, netflow		3	100002-suricata.xml	etc/rules
100002	Suricata Traffic - event_type .	suricata, netflow		3	100002-suricata.xml	etc/rules
100003	Security Onion - Alerta de Média Severidade	security_onion		10	security_onion_rules.xml	etc/rules
100003	Security Onion - Alerta de Média Severidade	security_onion		10	security_onion_rules.xml	etc/rules
100003	Suricata Alert - alert.signature . Signature ID: alert.signature_id .	suricata, suricata_severity2		10	100002-suricata.xml	etc/rules
100003	Suricata Alert - alert.signature . Signature ID: alert.signature_id .	suricata, suricata_severity2		10	100002-suricata.xml	etc/rules

Rows per page: 10 < 1 2 3 4 5 ... 444 >

Anexo 7: Regras centralizando os alertas do Security Onion no Wazuh.

Server Manager

Server Manager ▸ Local Server

Dashboard

Local Server

All Servers

AD DS

DNS

File and Storage Services ▸

PROPERTIES For WIN-CMMGK88RP2D

Computer name: WIN-CMMGK88RP2D

Domain: vidaplana.local

Last installed updates: Never

Windows Update: Download updates only, using Windows Update

Last checked for updates: 6/11/2026 6:00 PM

Microsoft Defender Firewall: Public: On

Remote management: Enabled

Remote Desktop: Disabled

NIC Teaming: Disabled

Ethernet: 192.168.10.10, IPv6 enabled

Microsoft Defender Antivirus: Real-Time Protection: On

Feedback & Diagnostics: Settings

IE Enhanced Security Configuration: On

Time zone: (UTC-08:00) Pacific Time (US & Canada)

Product ID: 00455-50000-00001-AA858 (activated)

Operating system version: Microsoft Windows Server 2022 Datacenter Evaluation

Hardware information: QEMU Standard PC (Q35 + ICH9, 2009)

Processors: QEMU Virtual CPU version 2.5+, QEMU Virtual CPU version

Installed memory (RAM): 7.89 GB

Total disk space: 119.37 GB

EVENTS All events | 6 total

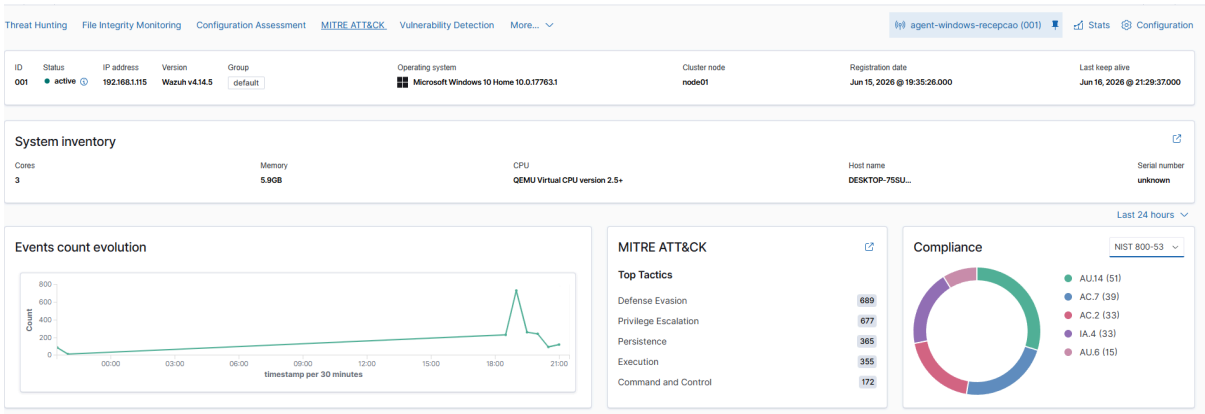
Filter

Server Name	ID	Severity	Source	Log	Date and Time
WIN-CMMGK88RP2D	10016	Warning	Microsoft-Windows-DistributedCOM	System	6/16/2026 10:02:10 PM
WIN-CMMGK88RP2D	12	Warning	Microsoft-Windows-Time-Service	System	6/16/2026 10:00:05 PM
WIN-CMMGK88RP2D	86	Error	Microsoft-Windows-CertificateServicesClient-CertEnroll	Application	6/16/2026 9:59:48 PM
WIN-CMMGK88RP2D	10154	Warning	Microsoft-Windows-Windows Remote Management	System	6/16/2026 9:59:47 PM
WIN-CMMGK88RP2D	1014	Warning	Microsoft-Windows-DNS-Client-Events	System	6/16/2026 9:59:25 PM

Type here to search

10:04 PM 6/16/2026

Anexo 8: Windows Server 2022 atualizado.



Anexo 9: Hardening do Windows.

Incidente MEDIUM: ET SCAN Potential SSH Scan Caixa de entrada



leonardo.o.feitosa@aluno.senai.br
para mim

Security Operations Center — Relatório Automático de Incidente

Reconhecimento / Varredura de Rede

MEDIUM **RECON**

IDENTIFICAÇÃO DO INCIDENTE

ID do Incidente	INC-1779409479582
Status	Aberto
Data/Hora do Alerta	21/05/2026, 21:22:02
Relatório Gerado em	21/05/2026, 21:24:39
Fonte de Detecção	suricata (IDS/IPS)

DETALHES DO ATAQUE

Assinatura Disparada	ET SCAN Potential SSH Scan
Categoria Detectada	Reconhecimento / Varredura de Rede
Severidade	MEDIUM

Anexo 10: Alerta chegando no e-mail, também será anexado juntamente com este relatório um vídeo da execução do ataque e um PDF de um exemplo de ataque.